

Tecplix.com — Black-Box Security Assessment

External attack-surface review: web estate, ServiceDesk Plus, and SSL-VPN gateway

Client	tecplix.com
Assessment date	30 September 2026
Perspective	Black-box only — unauthenticated, external vantage point. No authenticated access, no internal network access, no social engineering.
Method	Passive reconnaissance (certificate-transparency logs) → live host probing → version fingerprinting → unauthenticated surface enumeration → vendor advisory correlation
Request rate	Serialised, ≈1 request/second. No denial-of-service, no load or stress testing.
Out of scope	formsapi.jabwn.com (third-party form SaaS, not owned by the client) — not probed

1. Executive summary

Eight subdomains were enumerated from public certificate-transparency logs and probed from outside. The marketing frontend is in good shape: no exploitable XSS, no open redirect, no path traversal, no exposed secrets, and CDN scripts are SRI-pinned. The material risk sits in the supporting infrastructure.

Two findings dominate. First, the internet-exposed **ManageEngine ServiceDesk Plus MSP console runs build 15130, which is a confirmed-vulnerable version** for an authenticated remote-code-execution vulnerability (CVE-2026-12507) — a single version upgrade resolves it. Second, the **FortiGate SSL-VPN remote-access gateway's firmware version could not be determined from outside**, so its exposure to a series of actively-exploited pre-authentication CVEs can be neither confirmed nor ruled out; that version must be checked internally.

Everything else is moderate or low: a public contact-form key with no anti-automation, a marketing origin that bypasses the CDN's protection, an expired certificate on a decommissioned staging host, and missing security headers.

Severity	Count	Finding IDs
CRITICAL	0	—
HIGH	1	F1 — ServiceDesk Plus vulnerable build (CVE-2026-12507)
MEDIUM	2	F2 — contact form open relay · F3 — www origin bypasses CDN
LOW	5	F4 expired cert · F5 staging exposure · F6 client-side validation · F7 ?p= injection · F8 IP disclosure
INFO	3	F9 headers · F10 VPN config disclosure · F11 dead DNS name

2. Estate & attack surface

Subdomains were recovered from crt.sh certificate-transparency logs, then resolved and probed. Infrastructure is split across three providers, which materially affects the risk of each host.

Host	IP / hosting	Technology	Black-box result
servicedesk	Cloudflare (172.67.74.32)	ManageEngine ServiceDesk Plus MSP, build 15130	Exposed admin console — vulnerable build
ras (:8883)	106.51.111.154 / 119.82.111.154	FortiGate SSL-VPN (FortiOS)	Remote-access gateway — version unknown
www	13.234.38.94 (AWS ap-south-1)	Apache — not behind CDN	Origin exposure
tecplix.com	Cloudflare (104.26.1.198)	Static, jQuery 3.4.1	Clean frontend; form + header gaps
staging	52.66.170.10 (AWS us-east-1)	nginx	Decommissioned, expired cert, still public
docs	Vercel	Documentation site	HSTS present — no significant findings
t-dac	13.203.63.65 (AWS ap-south-1)	—	Resolves, no HTTP response (firewalled or dead)
ithelp	—	—	Dead DNS name, no dangling record

Negative result worth noting. The ServiceDesk console was probed for unauthenticated file exposure across 14 common paths (/cgi-bin/ , /StatusServlet , /ServerInfo , /api/json/v2/ , /CONTRIBUTING , /README and others). Every path returned HTTP 200, but byte-for-byte inspection confirmed all of them serve the *login page* (the j_username / j_password / loginForm markers are present) — a catch-all route, not directory traversal or stray-file leakage. No unauthenticated content disclosure was found on this host.

3. Findings — confirmed & actionable

F1 · ServiceDesk Plus MSP build 15130 is a confirmed-vulnerable version (CVE-2026-12507)

HIGH

Evidence (black-box)

- Login page title: `ManageEngine ServiceDesk Plus – MSP`.
- Every static asset carries a consistent build token: `/style/loginstyle.css?15130`, `/scripts/common-helpers.js?15130`, `/zohocomponents/css/zohocomponents.min.css?15130`.
- Corroborated against the vendor's own archive `archives.manageengine.com/service-desk/15130/` and the MSP release notes ("What's new in 15130", released 2 March 2026).
- Session cookie: `SDPSESSIONID=...; Secure; HttpOnly; SameSite=None`.
- Response headers: only `X-Content-Type-Options: nosniff` (and legacy `X-XSS-Protection`). No HSTS, CSP, or `X-Frame-Options`.

Why it matters

ManageEngine's advisory states ServiceDesk Plus **MSP is affected in build "15140 and below" and fixed in 15150** (shipped 22 June 2026). The deployed build 15130 falls inside the affected range. CVE-2026-12507 is a remote-code-execution flaw in the Reports module: an authenticated user holding the **"Create Query Reports"** permission can submit crafted database queries containing Jasper expressions and execute arbitrary commands on the host — typically as `SYSTEM` on Windows. It is not pre-authentication, but a single low-privilege technician account is enough, making it a realistic post-compromise or insider escalation step.

Separately, ServiceDesk Plus is a privileged ITSM administration plane (tickets, agents, integrations, configuration). It is reachable directly from the internet; the CDN in front masks the origin but provides no protection against application-layer authentication or code-execution flaws.

Related CVEs checked — not applicable

CVE	Impact	Affected (MSP)	This host
CVE-2026-56112	Pre-auth XXE → SSTI RCE chain (CVSS 9.1)	prior to 14.5.505 / 14505	Not affected — 15130 is well past the fix
CVE-2025-8309	Privilege escalation via URL regex	fixed 14940	Not affected — 15130 > 14940

The SOAP API endpoint `/sdppapi/` (associated with the 2026 XXE chain) is present and returns 200, confirming the same codebase, but the XXE is remediated at this build. It was not exploited.

Remediation

1. **Upgrade MSP to build 15150 or later** (ideally the current release). This is the highest-value single action in the engagement.
2. Until patched, restrict the "Create Query Reports" permission to trusted senior staff and audit Reports module logs for anomalous query activity.
3. Reduce internet exposure: place the console behind VPN, an IP allow-list, or an authenticating proxy such as Cloudflare Access.
4. Enforce MFA for all agents and administrators.
5. Deploy the missing security headers (see F9).
6. Confirm the build in-product via `Admin → About` before and after patching.

F2 · Public contact-form key with no anti-automation enables an unauthenticated content-injection relay

MEDIUM

Evidence (black-box, from the public JavaScript)

```
https://tecplix.com/script.js — sha256  
c4d0031976b24eb61e47616dcc760e46eb42c39a4733a70e7aa98fd1435b1c16
```

```
line 198: url: "https://formsapi.jabwn.com/key/BJGeKt4djG4HhGa7r8jw", ← public key  
line 196: paramObj['product'] = product || 'Tecplix';  
line 142: $.get("https://api.ipify.org?format=json", function(data) { clientIp = data.ip; });
```

The form is declared `novalidate` and every validation rule is client-side. A scan of the contact page for `honeypot|captcha|recaptcha|turnstile|csrf|_token` returned **zero matches** — no CAPTCHA, no honeypot, no rate limiting, and no first-party server-side endpoint.

Why it matters

The browser posts directly from the visitor's machine to the third-party form service, so there is no Tecplix-controlled server in the path to enforce anything. The key is in view-source. Because the request uses `application/x-www-form-urlencoded` — a CORS *simple* content type — browsers send **no preflight**, meaning any website a visitor visits can submit the form cross-origin without interaction. The recipient, message fields, and product value are all client-supplied. An attacker can therefore deliver arbitrary content into a Tecplix-branded sales workflow, where it is more likely to be actioned by staff than a random email.

Remediation

Because the endpoint belongs to a third party, client-side changes cannot fully fix this. Introduce a server-side proxy (for example a serverless function) that receives the submission, applies per-IP rate limiting, Turnstile verification and a honeypot, and only then forwards to the form provider. Separately, ask the provider whether the key supports domain restriction and whether the `to:` field accepts arbitrary recipients.

F3 · www.tecplix.com serves from a separate origin that bypasses the CDN

MEDIUM

Evidence (black-box)

Host	Resolved IP	Server	Path
tecplix.com	104.26.1.198	Cloudflare	Proxied
www.tecplix.com	13.234.38.94	Apache HTTP Server	Direct to origin

Both serve identical content (`Tecplix Technologies | Enhanced Cyber Resilience`).

Why it matters

The apex domain enjoys the CDN's protection, but `www` is reached without it. Any edge WAF rules, bot controls or header policy configured at the CDN therefore do not apply to `www`, and the real origin IP is publicly known. It also creates an inconsistency: the same site is served through two different TLS and header paths, so hardening applied to one may silently not apply to the other.

Remediation

Place `www` behind the CDN on the same account and policy, or canonicalise `www` → apex at the edge. Independently, restrict the origin server to accept traffic only from the CDN's published address ranges.

4. Findings — lower severity

F4 · Expired TLS certificate on staging.tecplix.com

LOW

```
subject = CN=staging.tecplix.com
issuer  = Let's Encrypt (R10)
notBefore= Oct  5 12:18:42 2024 GMT
notAfter = Jan  3 12:18:41 2025 GMT    ← expired 634 days before assessment
```

The certificate has not renewed in roughly 1.7 years, indicating a broken renewal or monitoring process independent of the site itself. **Remediation:** restore automated renewal, or — if the host is not needed (F5) — delete the DNS record and certificate now.

F5 · Decommissioned staging host remains publicly reachable

LOW

Every request to the host returns HTTP `421 Misdirected Request` from the nginx default virtual host — confirmed via direct request, IP-direct with a `Host` header, and an alternate path. The hostname resolves and the host completes TLS, but no application vhost is configured. Nothing exploitable is currently running, but the host is unnecessary public attack surface and could host content unnoticed.

Remediation: remove the DNS record and decommission the server; confirm nothing else is hosted on 52.66.170.10.

F6 · All contact-form validation is client-side only

LOW

The form uses `novalidate` with every rule implemented in jQuery (`script.js` lines 164–190), including a free-mail blocklist whose outer group is optional and therefore matches too broadly, and which omits many disposable providers. A direct request bypasses it entirely. **Remediation:** enforce rules server-side; if lead qualification matters, use a maintained disposable-domain list rather than a client-side denylist.

F7 · `?p=` parameter flows unsanitised into the sales notification

LOW

`script.js:148` reads `const product = urlParams.get('p')` and line 196 places it into the submission with no validation. The value is never rendered into the page, so this is *not* a cross-site scripting vector on the client. Because the other message fields are attacker-controlled by design, the added capability is limited — but if the field is used in an email subject it becomes a subject-injection primitive. **Remediation:** allow-list the parameter against a fixed product catalogue, or strip it to safe characters and cap its length.

F8 · Visitor IP address disclosed to an unrelated third party

LOW

`script.js:142–145` calls `https://api.ipify.org` on page load, before any form interaction and without consent or notice; the result is then embedded in submissions. Given that EMEA, Europe, JAPAC and North American operations are advertised, this is a data-minimisation and privacy consideration. **Remediation:** derive the client IP server-side and remove the third-party call; if the field is required, capture it in the server-side proxy recommended in F2.

F9 · No security response headers on the marketing site

INFO

Response headers for `GET https://tecplix.com/` contain none of the standard set: missing `Strict-Transport-Security`, `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy` and `Permissions-Policy`. No `security.txt` is published. The `docs` subdomain does send HSTS, so this is a gap in the main site's configuration rather than a blanket absence.

The absent `X-Frame-Options` / `frame-ancestors` means the contact page can be framed by any origin; combined with a contact form, this is of phishing-lure value. No working clickjacking exploit chain was demonstrated, so it is not rated above informational. **Remediation:** add a headers file at the edge, initially in report-only mode, then enforce. The embedded office map requires `frame-src https://maps.google.com` in the policy.

F10 · SSL-VPN portal discloses internal configuration before authentication

INFO

An unauthenticated `GET /api/v2/service/login-config` on `ras.tecplix.com:8883` returns the per-host cookie identifier and the CSRF and management-override cookie names, and confirms that SAML single sign-on is disabled while two-factor token push is available. Only names and a host hash are exposed — no secrets — so the impact is reconnaissance value. The portal's security posture is otherwise reasonable: HSTS is present with a two-year max-age, a restrictive content-security-policy with `frame-ancestors 'self'` is set, and session cookies are `HttpOnly; Secure; SameSite=Strict`.

Remediation: restrict exposure of the portal's administrative API paths; verify that two-factor authentication is *enforced* for every user rather than optional, and disable local administrator access via VPN.

F11 · Dead DNS record with certificate history

INFO

`ithelp.tecplix.com` appears in certificate-transparency logs but currently has no A or CNAME record. It was checked for a dangling alias that could allow third-party takeover; none exists, so **no takeover path was found**.

Remediation: delete the stale record to reduce the certificate-transparency and DNS attack surface.

5. Unresolved — requires internal access

SSL-VPN firmware version could not be determined from outside. The portal at `ras.tecplix.com:8883` is a FortiGate remote-access gateway. Its version is not exposed prior to login, and every pre-authentication CVE for this product class is gated on the running build. From an external viewpoint the exposure therefore *cannot be confirmed or ruled out*, and the following actively-exploited issues may apply depending on the installed version:

CVE	Impact	Fixed in
CVE-2026-39801 KEV	Pre-auth RCE, heap out-of-bounds write (CVSS 9.8); mass-exploited after disclosure	7.6.2 · 7.4.8 · 7.2.12 · 7.0.18
CVE-2024-21762 KEV	Pre-auth RCE, stack overflow (CVSS 9.8)	7.4.3 · 7.2.7 · 7.0.14 · 6.4.15
CVE-2024-55591	Authentication bypass leading to super-admin	7.0.17 · 7.2.13 · 7.4.3
CVE-2023-42789 / 42790 / 42793	Pre-auth heap overflow — code execution and denial of service	7.2.4 · 7.0.14
CVE-2025-68686 KEV	Bypass of the symlink-persistence fix; not remotely testable — requires a prior compromise	7.6.2 · 7.4.7 (7.2/7.0/6.4: migrate)

Requested from the client: supply the firmware version (`GUI System` → `Firmware`, or `get system status`) so exposure can be determined precisely. Alongside patching, a compromise review is warranted because patching does not remove implants — the symlink-persistence class of attack is designed to survive exactly that.

Additionally, `t-dac.tecplix.com` resolves to 13.203.63.65 but returned no HTTP response from an external vantage point. It is either firewalled against the internet or not running; this could not be distinguished without internal access.

6. What was tested and found clean

Recording negative results prevents duplicated effort and documents the coverage of this assessment.

Control tested	Target(s)	Result
Reflected & DOM cross-site scripting	tecplix.com, www, four tool pages	No parameter reaches <code>innerHTML</code> ; calculator state only
Open redirect	tecplix.com	No user input in navigation targets
Path traversal	tecplix.com blog slug	Input is encoded; no traversal
Sub-resource integrity	tecplix.com	Present on CDN scripts
Secrets in client-side code	tecplix.com	None
Version-control & config exposure	tecplix.com	No <code>.git</code> , <code>.env</code> or source maps served
Unauthenticated file disclosure	servicedesk	Catch-all returns login page only
Subdomain takeover	ithelp, t-dac, staging	No dangling third-party aliases
Transport security	docs, servicedesk, ras	docs and ras send HSTS; servicedesk and apex do not

7. Prioritised remediation plan

Priority	Action	Findings
P0 — immediate	Upgrade ServiceDesk Plus MSP to build 15150 or later	F1
P0 — immediate	Place <code>www</code> behind the CDN; restrict the origin to CDN ranges	F3
P1 — this week	Obtain the VPN firmware version; patch to a fixed build; hunt for indicators of compromise; enforce MFA	§5
P1 — this week	Introduce a rate-limited, challenge-protected server-side proxy in front of the contact form	F2
P1 — this week	Deploy HSTS, CSP, X-Frame-Options and Referrer-Policy across the estate	F9
P2 — this month	Remove the expired staging certificate and the dead DNS record	F4, F5, F11
P2 — this month	Enforce form validation server-side; sanitise the product parameter; remove the IP-lookup call	F6, F7, F8
P3 — maintenance	Upgrade jQuery to a supported release and re-pin the integrity hash	§8

8. Dependency note

The marketing site loads jQuery 3.4.1, which predates the 3.5.0 release that addressed CVE-2020-11022 and CVE-2020-11023. Exploitation of those issues requires untrusted HTML to be passed to jQuery's DOM-manipulation methods; no such sink was identified on any tested page, and the script is loaded with an integrity attribute that mitigates tampering. It is therefore reported as an outdated-dependency risk rather than a confirmed vulnerability. Upgrading to a currently supported 3.x release and re-pinning the hash is recommended.

9. Methodology and limitations

This was a black-box assessment performed entirely from an external vantage point without credentials. Host discovery began with passive certificate-transparency data rather than active scanning, consistent with the constraints of the engagement. All testing was serialised at approximately one request per second.

Limitations to note when interpreting these results: no authenticated functionality was assessed, so the ServiceDesk console's post-login attack surface, the VPN portal's authenticated configuration, and any administrative interfaces remain unreviewed. The third-party form endpoint was excluded by ownership. No vulnerability was verified by exploitation against production infrastructure, and no denial-of-service, load, or stress testing was performed. Findings marked as requiring internal access depend on information the client must supply.

Prepared from black-box testing of the `tecplix.com` domain and its subdomains on 30 September 2026. Findings are stated to the best of the external evidence available at the time of assessment; version-dependent conclusions should be re-verified against the vendor's current advisory feed at the time of remediation.